

RBAC V3 — Postman Testing Guide

Base URL: `http://localhost:8080` (adjust as needed) **Date:** September 12, 2026

Prerequisites

1. Server running (`./mvnw spring-boot:run`)
 2. Postman installed
 3. Import the collection from `docs/postman/RBAC-V3.postman_collection.json`
-

Phase 1: Super Admin Setup

Step 1.1 — Register Super Admin

POST `{{baseUrl}}/api/v1/super-admin/register`

Body:

```
{
  "data": {
    "username": "superadmin",
    "email": "admin@system.com",
    "password": "Test@123",
    "fullName": "Super Admin",
    "mobileNo": "9800000000",
    "secretKey": "your-registration-secret"
  }
}
```

Expected: 200 OK with `userId`

Step 1.2 — Login Super Admin

POST `{{baseUrl}}/api/v1/super-admin/login`

Body:

```
{
  "data": {
    "username": "superadmin",
    "password": "Test@123"
  }
}
```

Expected: 200 OK with `accessToken` (or MFA challenge if MFA enabled)

Save the `accessToken` as collection variable `{{saToken}}`

Phase 2: Create a Firm

Step 2.1 — Create Firm

```
POST {{baseUrl}}/api/v1/super-admin/firms
Headers: Authorization: Bearer {{saToken}}
```

Body:

```
{
  "data": {
    "lawFirmCode": "TESTFIRM",
    "name": "Test Law Firm",
    "firmType": "FIRM",
    "email": "info@testfirm.com",
    "phone": "9800000010",
    "adminUsername": "firmadmin",
    "adminEmail": "admin@testfirm.com",
    "adminMobileNo": "9800000011",
    "adminPassword": "AdminPass123!",
    "adminFullName": "Firm Admin User"
  }
}
```

Expected: 200 OK with `firmId`, `adminUserId`, `lawFirmCode`

Save `firmId` as `{{firmId}}` **Save** `adminUserId` as `{{firmAdminUserId}}`

Step 2.2 — Verify Firm Roles Created

```
GET {{baseUrl}}/api/v1/super-admin/firms/{{firmId}}/roles
Headers: Authorization: Bearer {{saToken}}
```

Expected: 4 roles — FIRM_ADMIN, ADVOCATE, PARALEGAL, CLIENT (all with 0 permissions)

Save the FIRM_ADMIN role ID as `{{firmAdminRoleId}}`

Phase 3: Set FIRM_ADMIN Permissions (The Ceiling)

Step 3.1 — View Available Permissions

```
GET {{baseUrl}}/api/v1/admin/roles
Headers: Authorization: Bearer {{saToken}}
```

This shows all system roles. Note the FIRM_ADMIN role's permissions — these are the defaults from the seed matrix.

Step 3.2 — Set FIRM_ADMIN Permissions for the Firm

```
PUT {{baseUrl}}/api/v1/super-admin/firms/{{firmId}}/roles/{{firmAdminRoleId}}/permissions
Headers: Authorization: Bearer {{saToken}}
```

Body:

```
{
  "data": {
    "roleId": "{{firmAdminRoleId}}",
    "permissionIds": [
      "<CASE_MANAGEMENT_VIEW_ID>",
    ]
  }
}
```

```

    "<CASE_MANAGEMENT_CREATE_ID>",
    "<CASE_MANAGEMENT_EDIT_ID>",
    "<BILLING_VIEW_ID>",
    "<USER_MANAGEMENT_VIEW_ID>",
    "<USER_MANAGEMENT_EDIT_ID>",
    "<ROLE_MANAGEMENT_VIEW_ID>",
    "<DASHBOARD_MANAGEMENT_VIEW_ID>",
    "<DASHBOARD_MANAGEMENT_ACCESS_ID>"
  ]
}
}

```

Note: You need actual permission UUIDs. Get them from:

```
GET {{baseUrl}}/api/v1/admin/roles
```

Then find the FIRM_ADMIN system role and copy its permission IDs.

Expected: 200 OK with the permissions list

This IS the ceiling. The Firm Admin can now distribute these 9 permissions to employee roles.

Phase 4: Firm Admin Login & Distribute Permissions

Step 4.1 — Login as Firm Admin

```
POST {{baseUrl}}/api/v1/auth/login
```

Body:

```

{
  "data": {
    "lawFirmCode": "TESTFIRM",
    "username": "firmadmin",
    "password": "AdminPass123!"
  }
}

```

Expected: 200 OK with accessToken

Save as {{firmToken}}

Note: If mustChangePassword is true, you'll get PASSWORD_CHANGE_REQUIRED with a passwordChangeToken . Use that to change password first:

```

POST {{baseUrl}}/api/v1/auth/change-password
Body: { "data": { "token": "<passwordChangeToken>", "newPassword": "NewPass123!" } }

```

Then login again with the new password.

Step 4.2 — View Firm Roles

```

GET {{baseUrl}}/api/v1/firm/roles
Headers: Authorization: Bearer {{firmToken}}

```

Expected: 4 roles with user counts

Step 4.3 — View ADVOCATE Permissions & Ceiling

```
GET {{baseUrl}}/api/v1/firm/roles/{{advocateRoleId}}/permissions
Headers: Authorization: Bearer {{firmToken}}
```

Expected Response:

```
{
  "data": {
    "roleId": "...",
    "roleName": "ADVOCATE",
    "roleCode": "ADVOCATE",
    "currentPermissions": [],
    "availablePermissions": [
      { "id": "...", "code": "CASE_MANAGEMENT:VIEW", "assigned": false },
      { "id": "...", "code": "CASE_MANAGEMENT:CREATE", "assigned": false },
      ...
    ]
  }
}
```

Key: `availablePermissions` shows the ceiling (FIRM_ADMIN's 9 permissions). `currentPermissions` is empty.

Step 4.4 — Assign Permissions to ADVOCATE

```
PUT {{baseUrl}}/api/v1/firm/roles/{{advocateRoleId}}/permissions
Headers: Authorization: Bearer {{firmToken}}
```

Body:

```
{
  "data": {
    "roleId": "{{advocateRoleId}}",
    "permissionIds": [
      "<CASE_MANAGEMENT_VIEW_ID>",
      "<CASE_MANAGEMENT_CREATE_ID>",
      "<DASHBOARD_MANAGEMENT_VIEW_ID>"
    ]
  }
}
```

Expected: `200 OK` with 3 permissions

Step 4.5 — Assign Permissions to PARALEGAL

```
PUT {{baseUrl}}/api/v1/firm/roles/{{paralegalRoleId}}/permissions
Headers: Authorization: Bearer {{firmToken}}
```

Body:

```
{
  "data": {
    "roleId": "{{paralegalRoleId}}",
    "permissionIds": [
```

```
    "<CASE_MANAGEMENT_VIEW_ID>",
    "<BILLING_VIEW_ID>"
  ]
}
```

Expected: 200 OK with 2 permissions

Step 4.6 — Verify Ceiling Enforcement

Try to assign a permission NOT in the ceiling:

```
PUT {{baseUrl}}/api/v1/firm/roles/{{advocateRoleId}}/permissions
Headers: Authorization: Bearer {{firmToken}}
```

Body:

```
{
  "data": {
    "roleId": "{{advocateRoleId}}",
    "permissionIds": [
      "<SCRAPER_MANAGEMENT_VIEW_ID>"
    ]
  }
}
```

Expected: 403 Forbidden — "Permission exceeds the ceiling"

Phase 5: SA Creates Custom Role On-Behalf

Step 5.1 — Create Custom Role

```
POST {{baseUrl}}/api/v1/super-admin/firms/{{firmId}}/roles
Headers: Authorization: Bearer {{saToken}}
```

Body:

```
{
  "data": {
    "name": "Senior Advocate",
    "code": "SENIOR_ADVOCATE",
    "description": "Senior advocate with extended permissions"
  }
}
```

Expected: 200 OK with role ID

Save as {{customRoleId}}

Step 5.2 — Assign Permissions to Custom Role

```
PUT {{baseUrl}}/api/v1/super-admin/firms/{{firmId}}/roles/{{customRoleId}}/permissions
Headers: Authorization: Bearer {{saToken}}
```

Body:

```
{
  "data": {
    "roleId": "{{customRoleId}}",
    "permissionIds": [
      "<CASE_MANAGEMENT_VIEW_ID>",
      "<CASE_MANAGEMENT_CREATE_ID>",
      "<CASE_MANAGEMENT_EDIT_ID>",
      "<CASE_MANAGEMENT_DELETE_ID>",
      "<BILLING_VIEW_ID>",
      "<BILLING_APPROVE_ID>"
    ]
  }
}
```

Expected: 200 OK — SA can assign ANY non-GLOBAL permission (no ceiling)

Step 5.3 — Verify Custom Role Visible to Firm Admin

```
GET {{baseUrl}}/api/v1/firm/roles
Headers: Authorization: Bearer {{firmToken}}
```

Expected: 5 roles now (FIRM_ADMIN, ADVOCATE, PARALEGAL, CLIENT, SENIOR_ADVOCATE)

Phase 6: Multi-Firm Isolation Test

Step 6.1 — Create Firm B

```
POST {{baseUrl}}/api/v1/super-admin/firms
Headers: Authorization: Bearer {{saToken}}
```

Body:

```
{
  "data": {
    "lawFirmCode": "FIRMB",
    "name": "Firm B",
    "firmType": "FIRM",
    "email": "info@firmB.com",
    "phone": "9800000020",
    "adminUsername": "firmBadmin",
    "adminEmail": "admin@firmB.com",
    "adminMobileNo": "9800000021",
    "adminPassword": "AdminPass123!",
    "adminFullName": "Firm B Admin"
  }
}
```

Step 6.2 — Set Firm B's FIRM_ADMIN Permissions

```
PUT {{baseUrl}}/api/v1/super-admin/firms/{{firmBId}}/roles/{{firmBAdminRoleId}}/permissions
Headers: Authorization: Bearer {{saToken}}
```

Body:

```
{
  "data": {
    "roleId": "{{firmBAdminRoleId}}",
    "permissionIds": [
      "<CASE_MANAGEMENT_VIEW_ID>"
    ]
  }
}
```

Step 6.3 — Verify Isolation

Firm B's FIRM_ADMIN has only 1 permission. Firm A's FIRM_ADMIN still has 9. They don't conflict.

Phase 7: Firm Admin Narrows Own Permissions

Step 7.1 — Firm Admin Removes a Permission from Themselves

```
PUT {{baseUrl}}/api/v1/firm/roles/{{firmAdminRoleId}}/permissions
Headers: Authorization: Bearer {{firmToken}}
```

Body (without BILLING:VIEW):

```
{
  "data": {
    "roleId": "{{firmAdminRoleId}}",
    "permissionIds": [
      "<CASE_MANAGEMENT_VIEW_ID>",
      "<CASE_MANAGEMENT_CREATE_ID>",
      "<CASE_MANAGEMENT_EDIT_ID>",
      "<USER_MANAGEMENT_VIEW_ID>",
      "<USER_MANAGEMENT_EDIT_ID>",
      "<ROLE_MANAGEMENT_VIEW_ID>",
      "<DASHBOARD_MANAGEMENT_VIEW_ID>",
      "<DASHBOARD_MANAGEMENT_ACCESS_ID>"
    ]
  }
}
```

Step 7.2 — Verify Ceiling Changed

```
GET {{baseUrl}}/api/v1/firm/roles/{{advocateRoleId}}/permissions
Headers: Authorization: Bearer {{firmToken}}
```

Expected: `availablePermissions` no longer includes BILLING:VIEW

Step 7.3 — Try to Assign Removed Permission

```
PUT {{baseUrl}}/api/v1/firm/roles/{{advocateRoleId}}/permissions
Headers: Authorization: Bearer {{firmToken}}
```

Body:

```

{
  "data": {
    "roleId": "{{advocateRoleId}}",
    "permissionIds": ["<BILLING_VIEW_ID>"]
  }
}

```

Expected: 403 Forbidden — BILLING:VIEW is no longer in the ceiling

Quick Reference — All Endpoints

#	Method	Endpoint	Auth	Purpose
1	POST	/api/v1/super-admin/register	None	Register SA
2	POST	/api/v1/super-admin/login	None	Login SA
3	POST	/api/v1/super-admin/firms	SA	Create firm
4	GET	/api/v1/super-admin/firms/{id}/roles	SA	View firm roles
5	PUT	/api/v1/super-admin/firms/{id}/roles/{rid}/permissions	SA	Set role perms (override)
6	POST	/api/v1/super-admin/firms/{id}/roles	SA	Create custom role
7	POST	/api/v1/auth/login	None	Login firm user
8	GET	/api/v1/firm/roles	FirmAdmin	List firm roles
9	GET	/api/v1/firm/roles/{rid}/permissions	FirmAdmin	View perms + ceiling
10	PUT	/api/v1/firm/roles/{rid}/permissions	FirmAdmin	Update perms (within ceiling)
11	POST	/api/v1/firm/roles	FirmAdmin	Create custom role
12	DELETE	/api/v1/firm/roles/{rid}	FirmAdmin	Delete custom role
13	PATCH	/api/v1/firm/roles/{rid}/toggle	FirmAdmin	Toggle role status
14	GET	/api/v1/firm/roles/{rid}/users	FirmAdmin	List role users